



Enabling Reproducible Audit Evidence for Phishing-Report Workflows in a State Agency

Shiva H. Thapa

M.S. Cyber Operations – CYBR 698-51

Fa25 Cyber Operations Capstone Project

December 7, 2025

Repo: https://github.com/shiva-thapa-cohort6/repro_lab



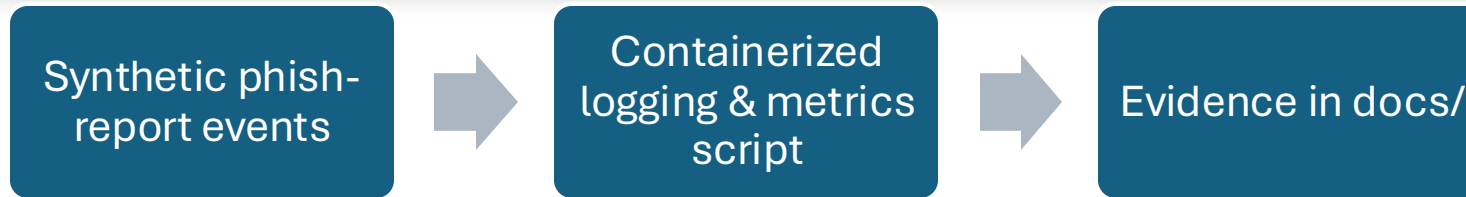
Phishing Reports Without Reliable Logs Undermine Response

- State agencies depend on staff phishing reports to detect targeted email attacks, but “Report Phish” workflows and logs are fragmented across email, ticketing, and SIEM tools.
 - Inconsistent audit evidence slows investigations and weakens monitoring and compliance.
 - Week-1 objectives call for a 25% increase in verified phishing reporting and a ≤ 2 -hour median time to detect, but those targets are hard to reach when phish-report logs are inconsistent and incomplete.
-

Evidence Snapshot From Prior Work

Source	Key Finding	Relevance to Design
Althobaiti et al., 2021 [2]	User phishing reports increase situational awareness but overwhelm analysts when evidence is inconsistent.	Motivates a standardized phish-report logging pipeline.
Killcrece & Ruefle, 2021 [3]	Structured, well-documented incident communication improves response quality and reduces confusion.	Supports clear, shareable log records for SOC and leadership.
ACSC, 2020 [4]	Legacy and opaque systems weaken monitoring despite formal control catalogs.	Justifies containerized, version-pinned analysis workflows with explicit metrics.

Containerized Phish-Report Logging Pipeline



- Single documented command builds the container image and regenerates all outputs from synthetic phish-report events.
- No real email content or identifiers are stored; all records are synthetic and schema-controlled.
- Metrics are computed automatically and written into docs/metric.txt for reuse in traceability discussions.
- **Key measures** : Reproducible Analysis Run Success Rate, Audit Record Retention Coverage, and Field Completeness Score (details on Evaluation slide).



Standards Anchors: CSF 2.0 and Zero Trust

Row / Block 1 – CSF Outcome

- **CSF 2.0 Outcome (Protect – Protective Security):**
PR.PS-04: “Log records are generated and made available for continuous monitoring.”
(NIST CSF 2.0, Appendix A, p. 20)
- **Design link:**
Each container run generates structured log records and metrics into known files (docs/log.txt, docs/metric.txt, docs/chart.png), making them available for continuous monitoring activities.

Row / Block 2 – ZTA Tenet

- **Zero Trust Tenet (SP 800-207):**
“The enterprise monitors and measures the integrity and security posture of all owned and associated assets.”
(NIST SP 800-207, Sec. 2.1, p. 7)
 - **Design link:**
Metrics such as run success rate and audit coverage treat the logging pipeline itself as an asset whose posture is monitored over time.
-



Ethics, Data Management, and C-SCRM

- **Ethics & privacy (ETHICS.md):** Only synthetic phishing-report events are used; no real names, internal email addresses, or message bodies are stored. Follows “minimum necessary” collection aligned with AC-6 and PT-3 in NIST SP 800-53 Rev. 5 AC-6 and PT-3.
 - **Data handling (DMP.md):** Synthetic events in data/, code in src/, output in docs/. Stored on encrypted local storage and a restricted cloud workspace; retention bounded to course requirements.
 - **C-SCRM (docs/cscrm_note.md):** Dependency risk from base container images and Python libraries is mitigated through version pinning, a simple SBOM, and basic hash checks before and after runs.
-



Evaluation Plan: SMART Metrics and Traceability

- **Reproducible Analysis Run Success Rate**
= successful container runs that produce expected outputs ÷ total runs in a defined period.
- **Audit Record Retention Coverage**
= events with logs spanning the configured time window ÷ total synthetic events.
- **Field Completeness Score**
= logs containing all required fields ÷ total logs sampled.

****Traceability chain:****

Risk → Requirement → Metric → Evidence:

missing or incomplete phishing audit records → NIST SP 800-171r3 03.03.03 → Reproducible Analysis Run Success Rate → evidence in docs/log.txt, docs/metric.txt, and docs/traceability.*.



CSF 2.0 Current → Target Profile

- **PR.PS-04 – Log records for continuous monitoring**

Current: Phish-related logs are fragmented and not demonstrably reproducible or complete.

Target: Synthetic phish-report events consistently produce reproducible, documented log records and metrics aligned with PR.PS-04.

- **DE.CM-01 – Networks and services are monitored**

Current: Monitoring of phishing events depends on scattered logs and manual reconstruction.

Target: Logging workflow provides a small, testable feed of structured events that can plug into broader monitoring.

- **GV.IM-03 – Measurement and improvement**

Current: Logging reliability and coverage are not measured consistently.

Target: Metrics and evidence in docs/ support routine evaluation of log generation and retention.

- PR.PS-04: “Log records are generated and made available for continuous monitoring.” (NIST CSF 2.0, App. A, p. 20)
-

Evidence-Standards Pages Used in Slides

NIST CSWP 29
February 26, 2024

The NIST Cybersecurity Framework (CSF) 2.0

- **PR.AA-05:** Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties
- **PR.AA-06:** Physical access to assets is managed, monitored, and enforced commensurate with risk
- **Awareness and Training (PR.AT):** The organization's personnel are provided with cybersecurity awareness and training so that they can perform their cybersecurity-related tasks
 - **PR.AT-01:** Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind
 - **PR.AT-02:** Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind
- **Data Security (PR.DS):** Data are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information
 - **PR.DS-01:** The confidentiality, integrity, and availability of data-at-rest are protected
 - **PR.DS-02:** The confidentiality, integrity, and availability of data-in-transit are protected
 - **PR.DS-10:** The confidentiality, integrity, and availability of data-in-use are protected
 - **PR.DS-11:** Backups of data are created, protected, maintained, and tested
- **Platform Security (PR.PS):** The hardware, software (e.g., firmware, operating systems, applications), and services of physical and virtual platforms are managed consistent with the organization's risk strategy to protect their confidentiality, integrity, and availability
 - **PR.PS-01:** Configuration management practices are established and applied
 - **PR.PS-02:** Software is maintained, replaced, and removed commensurate with risk
 - **PR.PS-03:** Hardware is maintained, replaced, and removed commensurate with risk
 - **PR.PS-04:** Log records are generated and made available for continuous monitoring
 - **PR.PS-05:** Installation and execution of unauthorized software are prevented
 - **PR.PS-06:** Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle
- **Technology Infrastructure Resilience (PR.IR):** Security architectures are managed with the organization's risk strategy to protect asset confidentiality, integrity, and availability, and organizational resilience
 - **PR.IR-01:** Networks and environments are protected from unauthorized logical access and usage

20

NIST CSF 2.0, Appendix A, p. 20 – PR.PS-04

NIST SP 800-207

ZERO TRUST ARCHITECTURE

network location, time, reported active attacks, etc. These rules and attributes are based on the needs of the business process and acceptable level of risk. Resource access and action permission policies can vary based on the sensitivity of the resource/data. Least privilege principles are applied to restrict both visibility and accessibility.

5. **The enterprise monitors and measures the integrity and security posture of all owned and associated assets.** No asset is inherently trusted. The enterprise evaluates the security posture of the asset when evaluating a resource request. An enterprise implementing a ZTA should establish a continuous diagnostics and mitigation (CDM) or similar system to monitor the state of devices and applications and should apply patches/fixes as needed. Assets that are discovered to be subverted, have known vulnerabilities, and/or are not managed by the enterprise may be treated differently (including denial of all connections to enterprise resources) than devices owned by or associated with the enterprise that are deemed to be in their most secure state. This may also apply to associated devices (e.g., personally owned devices) that may be allowed to access some resources but not others. This, too, requires a robust monitoring and reporting system in place to provide actionable data about the current state of enterprise resources.
6. **All resource authentication and authorization are dynamic and strictly enforced before access is allowed.** This is a constant cycle of obtaining access, scanning and assessing threats, adapting, and continually reevaluating trust in ongoing communication. An enterprise implementing a ZTA would be expected to have Identity, Credential, and Access Management (ICAM) and asset management systems in place. This includes the use of multifactor authentication (MFA) for access to some or all enterprise resources. Continual monitoring with possible reauthentication and reauthorization occurs throughout user transactions, as defined and enforced by policy (e.g., time-based, new resource requested, resource modification, anomalous subject activity detected) that strives to achieve a balance of security, availability, usability, and cost-efficiency.
7. **The enterprise collects as much information as possible about the current state of assets, network infrastructure and communications and uses it to improve its security posture.** An enterprise should collect data about asset security posture, network traffic and access requests, process that data, and use any insight gained to improve policy creation and enforcement. This data can also be used to provide context for access requests from subjects (see Section 3.3.1).

The above tenets attempt to be technology agnostic. For example, "user identification (ID)" could include several factors such as username/password, certificates, and one-time password. These tenets apply to work done within an organization or in collaboration with one or more partner organizations and not to anonymous public or consumer-facing business processes. An organization cannot impose internal policies on external actors (e.g., customers or general internet users) but may be able to implement some ZT-based policies on nonenterprise users who have a special relationship with the organization (e.g. registered customers, employee dependents, etc.).

7

NIST SP 800-207, p. 7 – Tenet 5